

Применение атрибутивных метаграфов для моделирования и выявления компьютерных атак

И.Т. Латыпов, М.А. Еремеев

Санкт-Петербургский государственный электротехнический университет «ЛЭТИ» им.
В.И. Ульянова (Ленина)

УДК 004.056.5

ББК 32.973.26-018.2

Abstract

Рассматривается подход к моделированию многоэтапных компьютерных атак с использованием атрибутивных метаграфов. Предложена формализованная трёхуровневая модель атаки — тактический, технический и методологический уровни, — позволяющая интегрировать экспертные знания о поведении злоумышленников, данные мониторинга информационных систем и требования нормативных документов. На основе методики ФСТЭК по определению угроз и фреймворка MITRE ATT&CK разработаны матрицы тактик, техник и методов, представленные в виде атрибутивных метаграфов. Приведена схема модели, описаны алгоритмы построения и анализа метаграфов, показана их применимость для оценки защищённости и автоматизированного обнаружения инцидентов в КИИ. Подчёркивается соответствие предложенного подхода требованиям Постановления Правительства РФ №555 и ГОСТ Р 57580.

Ключевые слова: атрибутивный метаграф, многоуровневая модель атаки, обнаружение инцидентов, методика ФСТЭК, MITRE ATT&CK, информационная безопасность, КИИ, графовые модели.

Abstract

An approach to modeling multi-stage cyberattacks using attributive metagraphs is considered. A formalized three-level attack model—tactical, technical, and methodological—is proposed, enabling the integration of expert knowledge about attacker behavior, monitoring data from information systems, and regulatory requirements. Based on the FSTEK methodology for threat identification and the MITRE ATT&CK framework, matrices of tactics, techniques, and methods are developed and represented as attributive metagraphs. The model architecture is illustrated, algorithms for metagraph construction and analysis are described, and their applicability for security assessment and automated incident detection in critical information infrastructures (CII) is demonstrated. The alignment of the proposed approach with the requirements of the Russian Government Decree No. 555 and GOST R 57580 is emphasized.

Keywords: attributive metagraph, multi-level attack model, incident detection, FSTEK methodology, MITRE ATT&CK, information security, critical information infrastructure (CII), graph-based models.

Введение

Современные информационные системы, особенно критически важные (КИИ), всё чаще становятся мишенью для целенаправленных, многоэтапных кибератак, реализуемых по сценариям, таким как APT (Advanced Persistent Threat). Такие атаки характеризуются высокой скрытностью, использованием легитимных инструментов (так называемый «living-off-the-land»), а также последовательным продвижением по цепочке киберубийства: от разведки и первоначального доступа до перемещения по сети, повышения привилегий и, наконец, экфильтрации данных. Традиционные средства защиты — сигнатурные IDS, антивирусы, системы анализа логов — часто не справляются с выявлением подобных угроз, поскольку они ориентированы на обнаружение отдельных событий, а не на анализ логики и последовательности действий злоумышленника.

В этой связи возрастает интерес к интеллектуальным методам моделирования угроз, способным учитывать не только факт совершения действия, но и его контекст, цель и место в общей стратегии атаки. Одним из перспективных направлений является применение графовых моделей, в частности — метаграфов. В отличие от классических графов, где рёбра соединяют только отдельные вершины, метаграфы позволяют моделировать сложные зависимости вида «если выполнены условия A, B и C, то возможно действие D». Это делает их особенно подходящими для описания логики реализации кибератак, где каждое действие зависит от предыдущих этапов и текущего состояния системы.

В работе [?] предложена многоуровневая модель компьютерной атаки, основанная на атрибутивных метаграфах, и введены матрицы тактик, техник и методов для её формализации. Настоящая статья развивает эту идею, адаптируя её к требованиям отечественной нормативной базы и расширяя теоретическую и прикладную составляющие. Особое внимание уделено связи с методикой ФСТЭК [?], Постановлением Правительства РФ №555 [?] и ГОСТ Р 57580 [?], что делает подход пригодным для практического применения в государственных и критически важных информационных системах.

Целью исследования является разработка формализованной модели атаки, пригодной как для оценки защищённости информационных систем, так и для автоматизированного обнаружения злонамеренного поведения в сетях КИИ.

1. Теоретические основы атрибутивных метаграфов

1.1. Формальное определение

Метаграф — это обобщение ориентированного гиперграфа, введённое в работах Basu и Blanning [?]. Он позволяет моделировать не только простые связи, но и сложные логические зависимости, что особенно важно при анализе поведения злоумышленника. Атрибутивный метаграф определяется как упорядоченная пятёрка:

$$\mathcal{M} = (V, E, \Sigma_V, \Sigma_E, \alpha), \quad (1)$$

где: [leftmargin=*,noitemsep]

- V — конечное множество вершин, представляющих сущности информационной системы (пользователи, хосты, процессы, файлы, сетевые соединения),
- $E \subseteq \mathcal{P}(V) \times \mathcal{P}(V)$ — множество метарёбер,
- Σ_V и Σ_E — алфавиты допустимых атрибутов,
- $\alpha : (V \cup E) \rightarrow (\Sigma_V \cup \Sigma_E)$ — функция атрибуции.

Каждое метаребро $e \in E$ задаётся парой непересекающихся подмножеств:

$$e = (X, Y), \quad X, Y \subseteq V, \quad X \cap Y = \emptyset, \quad (2)$$

где X — входное множество (in-set), Y — выходное (out-set).

1.2. Атрибутивное расширение

Функция атрибуции позволяет кодировать семантические характеристики:

$$\alpha(v) = \{(k_1, a_1), \dots, (k_n, a_n)\}, \quad k_i \in \Sigma_V. \quad (3)$$

Например: `tactic = "TA0010"`, `ip = "192.168.1.10"`.

2. Трёхуровневая модель компьютерной атаки

Модель включает:

- Тактический уровень — цели (Initial Access, Execution и др.),
- Технический уровень — техники (Phishing, PowerShell и др.),
- Методологический уровень — конкретные реализации (макросы, скрипты).

3. Матрицы тактик, техник и методов

На основе [?] и MITRE ATT&CK разработаны матрицы, формализованные в виде метаграфов. Каждая ячейка содержит:

- идентификатор (TA0001, T1566 и др.),
- описание,
- связь с требованиями ФСТЭК,
- примеры IoC.

4. Алгоритмы построения и анализа

4.1. Построение метаграфа

Исходные данные: логи, NetFlow, события SIEM. Этапы:

1. Нормализация,
2. Извлечение сущностей $\rightarrow V$,
3. Извлечение зависимостей $\rightarrow E$,
4. Назначение атрибутов $\rightarrow \alpha$.

4.2. Обнаружение атак

Пусть $\mathcal{M}_{\text{obs}}$ — текущий метаграф, $\mathcal{M}_{\text{pat}}$ — шаблон. Атака обнаружена, если существует $\phi : V_{\text{pat}} \rightarrow V_{\text{obs}}$, такое что:

$$\forall v \in V_{\text{pat}} : \alpha_{\text{pat}}(v) \subseteq \alpha_{\text{obs}}(\phi(v)) \quad \text{и} \quad \forall e = (X, Y) \in E_{\text{pat}} : (\phi(X), \phi(Y)) \in E_{\text{obs}}. \quad (4)$$

5. Соответствие нормативным требованиям

Подход соответствует:

- Постановлению №555 [?] — анализ угроз,
- Методике ФСТЭК [?] — формализация угроз,
- ГОСТ Р 57580 [?] — требования к обнаружению инцидентов.

6. Сравнение с другими подходами

Подход развивает идеи Зегжды Д.П. [?, ?] и дополняет методы Новохрестова и Конева [?], обеспечивая интерпретируемость и соответствие нормативам.

Заключение

Атрибутивные метаграфы позволяют создавать интерпретируемые, нормативно-ориентированные модели атак, пригодные для защиты КИИ. Перспективы — интеграция с GNN, онтологиями угроз и системами управления инцидентами.

Список литературы

1. Latypov I.T., Ereemeev M.A. Multilevel Model of Computer Attack Based on Attributive Metagraphs. Automatic Control and Computer Sciences, 2020, vol. 54, no. 8, pp. 944–948. DOI:10.3103/S0146411620080192
2. Методика определения угроз безопасности в информационных системах. — М.: ФСТЭК России, 2015.
3. Постановление Правительства РФ от 11.05.2017 №555.
4. ГОСТ Р 57580-2017. «Защита информации. Инциденты информационной безопасности. Термины и определения».
5. Basu A., Blanning R.W. Metagraphs in information modeling and analysis. IEEE Transactions on Systems, Man, and Cybernetics, 1994, vol. 24, no. 10, pp. 1463–1475.
6. MITRE ATT&CK® Framework. <https://attack.mitre.org/>
7. Mallon S. Extended Cyber Kill Chain. Black Hat USA 2016.
8. Zegzhda D.P., Stepanova T.V., Suprun A.F. Multiagent system controllability evaluation using the multilevel structure of the graph of agent. Autom. Control Comput. Sci., 2016, vol. 50, no. 8, pp. 809–812.
9. Zegzhda D., Zegzhda P., Pechenkin A., Poltavtseva M. Modeling of information systems to their security evaluation. ACM ICPS, 2017, pp. 295–298.
10. Novokhrestov A.K., Konev A.A. Assessment of the security quality of computer networks. Din. Sist. Mekh. Mash., 2014, no. 4, pp. 85–87.
11. Astanin S.V., Dragnysh N.V., Zhukovskaya N.K. Nested metagraphs as models of complex objects. 2012.
12. Gorbachev I.E. et al. Methodology for implementing a systematic approach in creating the image of the information security system of critical information infrastructure. Problems of Information Security. Computer Systems, 2018, no. 2, pp. 93–111.